



Planificación de los Objetivos de Seguridad de la Información

Semana 2
14 DE MAYO DE 2026



Gestión de la Seguridad

Actividad de integración: Lluvia de ideas guiada

Pregunta detonadora: "Si usted fuera el responsable de seguridad de una universidad, ¿cuáles serían los tres objetivos de seguridad de la información más importantes para el próximo año?"

Instrucciones para el estudiante:

- Tome 2 minutos para pensar y escribir sus tres objetivos.
- Comparta uno en el chat del aula o de viva voz.
- Identifique si su objetivo es medible y con plazo.

Instrucciones para el docente:

- Recoja entre 6 y 8 aportes.
- Clasifíquelos en pantalla como objetivos SMART o no SMART.
- Cierre la actividad mostrando que la mayoría de propuestas iniciales suelen ser vagas.

Duración: 10 minutos.



Cláusula 6.2 — ISO/IEC 27001

La cláusula 6.2 establece que la organización debe definir objetivos de seguridad de la información en las funciones y niveles pertinentes.

Estos objetivos deben:

- Ser coherentes con la política de seguridad.
- Ser medibles cuando sea posible.
- Considerar requisitos de seguridad aplicables y resultados de la valoración del riesgo.
- Ser comunicados y actualizados.
- Estar documentados.



Un objetivo de seguridad efectivo debe ser:

- S — Specific (Específico): aborda una situación concreta del SGSI.
- M — Measurable (Medible): incluye indicadores cuantificables.
- A — Achievable (Alcanzable): es realista con los recursos disponibles.
- R — Relevant (Relevante): alineado con la estrategia organizacional.
- T — Time-bound (Con plazo): tiene fecha de cumplimiento clara.

Ejemplo no SMART: "Mejorar la seguridad de la información".

Ejemplo SMART: "Reducir en un 30% los incidentes de phishing reportados antes del 31 de diciembre de 2026, mediante capacitación obligatoria al 100% del personal administrativo".



Pasos clave para establecer objetivos efectivos

Definición y alineación

Analizar el contexto organizacional.

Identificar partes interesadas y sus expectativas.

Alinear los objetivos con la estrategia y la política de seguridad.

Considerar requisitos legales y regulatorios.

Documentar los objetivos.

Operación y seguimiento

Asignar responsables y recursos.

Definir métricas e indicadores.

Establecer plazos concretos.

Comunicar los objetivos a todos los niveles.

Revisar, ajustar y mejorar continuamente.



Alineación estratégica

Los objetivos de seguridad deben respaldar la misión y visión de la organización.

La coherencia entre objetivos de seguridad y objetivos estratégicos facilita la integración del SGSI en la gestión global.

Resultado: los esfuerzos de seguridad fortalecen el éxito del negocio en lugar de obstaculizarlo.

Partes interesadas

Incluye a empleados, directivos, clientes, proveedores, reguladores y socios.

La participación de estos grupos asegura que sus intereses y necesidades sean considerados.

Resultado: mayor aceptación, apoyo y efectividad de las medidas de seguridad implementadas.



Análisis de riesgos: la planificación debe incluir la identificación y evaluación de riesgos que puedan obstaculizar el logro de los objetivos. Esto permite priorizar y diseñar controles efectivos.

Coordinación interna: los objetivos deben integrarse con la gestión de riesgos, el cumplimiento normativo y la administración de recursos humanos. La gestión aislada compromete la eficacia.

Alta dirección: debe garantizar la asignación de recursos, comunicar los objetivos a todos los niveles y fomentar una cultura de seguridad. No basta con aprobar: debe participar activamente.



Ejemplos de indicadores aplicables a objetivos de seguridad de la información:

- Porcentaje de incidentes de seguridad resueltos dentro del SLA.
- Número de vulnerabilidades críticas detectadas y mitigadas por trimestre.
- Porcentaje de personal capacitado en políticas de seguridad.
- Tiempo medio de detección (MTTD) y de respuesta (MTTR) ante incidentes.
- Cobertura de controles del Anexo A implementados.
- Porcentaje de cumplimiento de auditorías internas.

Las métricas deben ser específicas, objetivas, recolectables y revisables periódicamente.



Planificación en ISO 27001

Contexto: clínica privada que maneja historias clínicas electrónicas y debe cumplir Habeas Data.

Objetivo SMART propuesto: "Lograr el cifrado en reposo del 100% de las historias clínicas almacenadas en bases de datos productivas antes del 30 de junio de 2026, garantizando la confidencialidad exigida por la normativa vigente".

Análisis del objetivo:

- Específico: cifrado en reposo de historias clínicas.
- Medible: porcentaje de bases cifradas (100%).
- Alcanzable: con recursos asignados al área de infraestructura.
- Relevante: protege información sensible y cumple regulación.
- Con plazo: fecha límite definida.

Indicador asociado: porcentaje de bases productivas con cifrado activado.



La evaluación de esta semana se enfoca en la planificación de objetivos de seguridad según ISO/IEC 27001 e incluye preguntas sobre:

- Importancia de involucrar a las partes interesadas.
- Rol de la alta dirección en la definición y revisión.
- Consideración de los riesgos identificados.
- Coherencia con los objetivos estratégicos.
- Consistencia con el contexto organizacional.
- Coordinación con otras áreas (riesgos, cumplimiento, RR. HH.).
- Métricas de desempeño y evaluación continua.
- Aplicación del criterio SMART.
- Establecimiento de plazos.
- Consideración del análisis de riesgos y controles seleccionados.

Repase los conceptos vistos antes de presentar la evaluación





Práctica guiada en Python

Práctica: descripción general

Título: Validador y Monitor de Objetivos SMART para SGSI. Propósito: aplicar los criterios SMART a una lista de objetivos de seguridad y calcular indicadores básicos de cumplimiento.

Componentes necesarios:

- Navegador web.
- Cuenta de Google activa.
- Acceso a Google Colab.

Conexiones sugeridas:

- Ninguna conexión física.
- Solo conexión a internet estable.

Producto esperado: reporte automatizado que muestra cuáles objetivos cumplen el criterio SMART y cuál es el avance porcentual del SGSI.



 Loading slide...

 Loading slide...

Pasos para probar la práctica

Ingrese a <https://colab.research.google.com> con su cuenta de Google.

Cree un nuevo notebook con la opción "Archivo > Nuevo cuaderno".

Copie el código completo en una sola celda o divídalo en dos celdas (Parte 1 y Parte 2).

Ejecute las celdas con Shift + Enter o el botón de reproducción.

Observe el reporte generado en la salida.

Modifique los valores de avance, agregue un nuevo objetivo o cambie los plazos.

Ejecute nuevamente y analice cómo cambian los indicadores.

Guarde el notebook en su Google Drive para entregarlo como evidencia.



Producto esperado:

- Notebook funcional en Google Colab con el código ejecutado.
- Captura de pantalla del reporte generado.
- Modificación de al menos un objetivo y nueva ejecución del análisis.

Preguntas de análisis:

- ¿Por qué el OBJ-02 no cumple los criterios SMART y qué le falta?
- ¿Qué indicador agregado sería el más relevante para reportar a la alta dirección?
- ¿Cómo conectaría este validador con un sistema real de gestión documental?
- ¿Qué riesgos se podrían identificar al observar plazos vencidos o avances bajos?
- ¿Qué nuevo atributo agregaría a cada objetivo para enriquecer el análisis?



Socialización breve

Compartamos:

- Un hallazgo interesante al ejecutar el código.
- Una dificultad encontrada durante la práctica.
- Una idea para mejorar el validador.
- Una conexión entre lo programado y lo aprendido sobre la cláusula 6.2.

Tiempo total: 7 minutos.

Dinámica: turnos rápidos de 30 a 60 segundos por estudiante voluntario.



Resolución de dudas

Espacio abierto para resolver inquietudes sobre:

- Conceptos de la cláusula 6.2 de ISO/IEC 27001.
- Aplicación del criterio SMART.
- Métricas e indicadores del SGSI.
- Práctica en Python.
- Preparación para la evaluación de la semana.

Tiempo máximo: 10 minutos.



 Loading slide...